ISMS Scope and Context Document

Implementation of the Information Security Management System

(ISO/IEC 27001:2022)

Document Classification	Internal
Version	1.0
Dated	15/01/27
Document Owner	NX Technologies

Note: NX Technologies is a fictional company. This document is a sample created for learning and portfolio purposes only.

Document Governance & Control

Revision History

VERSION	DATE	AUTHOR	DESCRIPTION
1.0	15/01/27	Aarti Narwade	Initial draft for ISMS Scope and Context

Distribution

NAME	TITLE
Aakash	CEO
Suvarna	CISO
Rahul	CTO

Approval and Sign-Off

NAME	POSITION	SIGNATURE	DATE
Aakash	CEO	Signed	20/01/27
Suvarna	CISO	Signed	20/01/27
Rahul	CTO	Signed	20/01/27

CONTENTS

1. INTRODUCTION 3
2. ORGANIZATIONAL CONTEXT 4
2.1 Company Profile 4
2.2 Departmental Functions 4
2.3 Products and Services Scope 4
3. INTERNAL AND EXTERNAL ISSUES 5
3.1 Internal Issues Matrix 5
3.2 External Issues Matrix 5
4. INTERESTED PARTIES AND REQUIREMENTS 6
4.1 Interested Parties Matrix 6
4.2 Applicable Statutory and Regulatory Framework 6
5 PURPOSE AND SCOPE OF THE ISMS 7
5.1 Purpose 7
5.2 Scope Application 7
5.3 Potential Impact of an Information Security Incident 7
5.4 Information Security Objectives 8
5.5 Scope of the ISMS Boundaries 8
5.5.1 Organizational Scope 8
5.5.2 Products and Services Scope 9
5.5.3 Exclusions 9

1. INTRODUCTION

NX Technologies is dedicated to safeguarding the security of its business information against security incidents, breaches, and unexpected disruptions. To achieve this, the company has established an Information Security Management System (ISMS) in accordance with ISO/IEC 27001:2022, the internationally recognized standard for information security management.

This document outlines how the business operates, both the internal and external factors affecting it, and the potential consequences of a security breach. By identifying these elements, NX Technologies can implement the most effective mix of control measures to mitigate risk and ensure that response plans are in place and regularly tested to minimize the impact of any disruptions.

In particular, this document covers:

- The organizational context and profile of NX Technologies.
- Internal and external issues relevant to NX Technologies' business purpose.
- Interested parties pertinent to the ISMS and their specific security requirements.
- Applicable legal, regulatory, and contractual obligations.
- The boundary, applicability, and exclusions of the ISMS scope.

This document will be reviewed and updated annually by the CISO (Suvarna) or when significant organizational, operational, or threat landscape changes occur.

2. ORGANIZATIONAL CONTEXT

2.1 Company Profile

NX Technologies is a technology services firm specializing in information security training and advisory solutions. The company delivers customized security training, IT consulting, and risk management services to diverse sectors including financial institutions, government agencies, and multinational corporations.

Headquartered in Mumbai, India, NX Technologies operates with a centralized management structure for IT, HR, Finance, and Operations, while deploying regional consulting resources to client sites across target markets.

2.2 Departmental Functions

- **HR (Human Resources):** Responsible for recruitment, onboarding, talent management, security awareness integration, and enforcing personnel compliance with security policies.
- **Finance:** Manages corporate budgeting, financial reporting, accounting, client billing, and payroll management.
- **Marketing:** Oversees digital marketing, branding, lead generation, and client relationship initiation.
- **Operations Department:** Handles client communications, operational support, service delivery coordination, and feedback mechanisms.
- **Consulting and Advisory:** Regional and centralized teams delivering security advisory, risk management, and technical security assessments directly to client sites.

2.3 Products and Services Scope

- Information Security Training Services (Client-facing and customized employee programs).
- Security Advisory, Risk Assessment, and ISO 27001 Consulting Services.
- IT Infrastructure and Cybersecurity Managed Services.

3. INTERNAL AND EXTERNAL ISSUES

In accordance with ISO/IEC 27001:2022 Clause 4.1, NX Technologies has identified internal and external issues relevant to its strategic direction and security objectives.

3.1 Internal Issues Matrix

CATEGORY	INTERNAL FACTORS & SECURITY IMPLICATIONS
Organizational Structure & Strategy	Centralized leadership led by CEO (Aakash) and CISO (Suvarna). Focus on embedding robust security controls without hindering consulting flexibility.
Existing Security Posture	Basic security controls exist (password policies, basic encryption). Risk management frameworks, formal incident response, and continuous monitoring are undergoing formal standardization.
Capabilities & Resources	Technical expertise led by Technical Lead (Naresh) and Implementation Lead (Suresh), with dedicated internal audit oversight by Shankar. Dedicated cybersecurity skill development is ongoing.
Culture & Awareness	High security awareness in technical teams; cross-departmental awareness (HR, Finance, Operations) requires structured reinforcement (target 95% training completion).
Processes & Assets	Core business processes involve handling sensitive client IP, proprietary training modules, financial data, and cloud CRM systems.

3.2 External Issues Matrix

CATEGORY	EXTERNAL FACTORS & IMPACT ON ISMS
Legal & Regulatory Environment	Strict compliance requirements under the Digital Personal Data Protection (DPDP) Act 2023, IT Act 2000, and global data privacy standards (GDPR).
Market & Competitor Dynamics	Increasing client demand for ISO 27001 certification as a mandatory contractual prerequisite in government and enterprise sectors.
Threat Landscape & Tech Trends	Rise in cloud security risks, phishing, ransomware threats, and vulnerabilities associated with remote/hybrid working models.
Customer Expectations	Clients demand stringent confidentiality, zero-data-leakage guarantees, and verified compliance proofs.
Third-Party Dependencies	Dependence on third-party cloud data centers, AWS/Azure infrastructure, and external SaaS providers requiring strict vendor risk management.

4. INTERESTED PARTIES AND REQUIREMENTS

In accordance with ISO/IEC 27001:2022 Clause 4.2, NX Technologies has identified key internal and external stakeholders relevant to the ISMS.

4.1 Interested Parties Matrix

INTERESTED PARTY	LEGAL & REGULATORY REQUIREMENTS	CONTRACTUAL OBLIGATIONS	SPECIFIC NEEDS & EXPECTATIONS
Employees	Labor laws, DPDP Act 2023	Employment Contracts	Clear security guidelines, safe remote working tools, role clarity.
Clients / Customers	DPDP Act 2023, GDPR, IT Act 2000	Master Services Agreements, SLAs	Protection of client data, system availability, incident notification.
Executive Leadership	Corporate Governance Regulations	Board Accountability	Asset protection, business continuity, regulatory compliance, risk mitigation.
Suppliers & Cloud Vendors	Trade & Data Protection Laws	NDAs, Service Level Agreements	Clear security expectations, secure integration channels, timely billing.
Regulatory Bodies	DPDP Act 2023, IT Act 2000	Statutory Filings	Strict adherence to statutory cyber law, breach reporting compliance.
External Auditors	ISO/IEC 27001:2022 Standards	Audit Agreements	Transparent documentation, evidence of control effectiveness.

4.2 Applicable Statutory and Regulatory Framework

- Digital Personal Data Protection (DPDP) Act, 2023 (India)
- Information Technology Act, 2000 and IT Amendment Act, 2008
- General Data Protection Regulation (GDPR) - for international client interactions

5 PURPOSE AND SCOPE OF THE ISMS

5.1 Purpose

The purpose of the ISMS is to:

1. Understand the organization's needs and the necessity for establishing information security management policy and objectives.

2. Implement and operate controls and measures for managing the organization's overall capability to manage information security incidents.

3. Monitor and review the performance and effectiveness of the ISMS.

4. Continually improve the organization's information security based on objective measurement.

5.2 Scope Application

This purpose applies to the scope of the ISMS as defined below:

- **In-Scope:**
  - Operations at the Mumbai headquarters.
  - Departments: IT, HR, Finance, Operations, Marketing, Consulting and Advisory, Training, and other departments handling sensitive information.
  - Technology infrastructure, including the company website, cloud-based CRM system, and Third Party applications, Google workspace, employee laptops.
  - Information assets: Client data, proprietary training materials, and internal intellectual property.
- **Out-of-Scope:**
  - Personal devices of employees not used for business purposes.
  - Activities unrelated to information security.

5.3 Potential Impact of an Information Security Incident

The impact of an incident will vary based on its nature, and a thorough risk assessment is conducted to identify and mitigate foreseeable risks. Generally, the disruption of normal business processes may affect one or more of the following key areas:

- Imposition of fines and other sanctions
- Missed business opportunities
- Violation of contractual commitments
- Failure to comply with legal requirements
- Damage to reputation and loss of customer trust
- Reduction in sales revenue

5.4 Information Security Objectives

Based on the requirements and issues set out in this document, the following major objectives are set for information security:

- Protecting client and internal data from unauthorized access, ensuring that only authorized individuals can view or modify sensitive information.
- Ensuring the accuracy and consistency of data throughout its lifecycle, and preventing unauthorized changes to critical business or information assets.
- Maintaining uninterrupted access to key systems, services, and information, ensuring that business operations continue smoothly without delays caused by security incidents.
- Ensuring the organization meets all applicable regulations, such as GDPR, the Digital Personal Data Protection Act (DPDP) in India, and contractual obligations with clients.
- Identifying, assessing, and mitigating security risks.
- Safeguarding the organization from various cyber threats.
- Managing security risks associated with third-party vendors and suppliers.
- Raising awareness and providing regular training to employees on information security.

The success of the ISMS will be judged on its ability to meet these overall objectives.

5.5 Scope of the ISMS Boundaries

5.5.1 Organizational Scope

The defined scope of NX Technologies ISMS considers the internal and external issues referred to in sections 3.1 and 3.2 of this document, the requirements referred to in section 4. It also reflects the needs of interested parties and the legal and regulatory requirements that are applicable to the organization.

The scope is defined below in terms of the parts of the organization, products and services, and related activities.

The ISMS includes the following parts of the NX Technologies organization (Operations and Marketing activities are covered as supporting business activities in section 5.5.2):

- **Consulting and Advisory Services:** Provides information security consulting to clients, handling sensitive client data and offering expert advice.
- **Information Security Training Services:** Conducts client and in-house training on information security practices, storing sensitive materials.
- **IT Department:** Manages internal IT infrastructure, systems, and cybersecurity.
- **Human Resources (HR):** Handles personal employee data, such as payroll and contracts.
- **Finance Department:** Manages financial data, including transactions, reports, and sensitive client financial information.
- **Geographical Locations:**
  - **Corporate Headquarters in Mumbai, India:** This is the central hub where most of the business functions, such as consulting, HR, and IT, are located.

- **Remote Work Locations:** Employees working remotely, especially those handling sensitive client data, are part of the ISMS scope. Client premises are outside the scope, but NX Technologies staff, devices and information used at client sites remain in scope.
- **Outsourced Processes:**
- Third-Party Applications: Any External applications and services used by employees for training, learning, and skill development.
- **Cloud Storage Provider (AWS/Azure):** The company's sensitive data is stored in cloud infrastructure managed by third parties, but under NX Technologies' control for access and security.

- **Organizational Boundaries:**
  - **NX Technologies** is the fictional organization covered by this ISMS. For this sample project, NX Technologies is treated as a single independent legal entity, and no subsidiaries are included within the ISMS scope.
  - **Directly Linked Functions:** Any services provided by external partners that are directly linked to the business functions of NX Technologies fall under the ISMS.

5.5.2 Products and Services Scope

The following products and services are within the scope of the ISMS:

- **Information Security Training Services:** Delivery of customized information security training to clients and internal employees.
- **Security Advisory and Consulting Services:** Provision of security advisory, risk assessment, and ISO 27001 consulting services.
- **IT Infrastructure and Cybersecurity Managed Services**: Management and support of IT infrastructure and cybersecurity services.
- **Supporting Business Activities**: HR, Finance, Marketing (excluding social media management, see section 5.5.3), and Operations activities that support service delivery and handle organizational or client information.

5.5.3 Exclusions

The following areas are specifically excluded from the scope of the ISMS:

- **General Administrative Support:**
  - **Reason for Exclusion:** General administrative functions, such as office management and event coordination, do not process or store sensitive information. These functions are not critical to the security posture of the organization.

- **Exclusion of Public Training Materials:**
  - **Reason for Exclusion:** Publicly available training materials and resources that are designed for broad audiences do not contain any sensitive information or confidential data. These materials are already protected by general access control and copyright protections.

- **Social Media Management:**
  - **Reason for Exclusion:** Social media activities, including content posting and engagement, are excluded from the ISMS as they do not involve the handling of sensitive information. Security controls on these platforms are managed separately under the social media guidelines.